

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

GRC Engineering (CGRCE) – Level 8 (Phase 2)

EXA CODE: GRC4991

EXAM TITLE: APPLIED GRC CASE STUDY ANALYSIS

TIME ALLOWED: 3 Hours

TOTAL MARKS: 100 Marks

PHASE: 2 (Final Examination)

STATUS: Mandatory

INSTRUCTIONS TO CANDIDATES:

- 1 This paper consists of **THREE (3) SECTIONS**.
- 2 You are required to answer **ALL** questions in all sections.
- 3 Ensure your answers are grounded in **GRC Engineering principles**, automation frameworks, and relevant regulatory standards (e.g., ISO 27001, NIST, NDPR/NDPA).
- 4 Use diagrams where necessary to illustrate engineering architectures or risk workflows.
- 5 **Academic Integrity:** Any form of malpractice will result in immediate disqualification.

SECTION A: GRC ENGINEERING & AUTOMATION (30 MARKS)

Question 1: The Evolution of Controls (15 Marks) Traditional GRC relies on manual audits and periodic reviews. As a GRC Engineer, you are tasked with transitioning a legacy organization to a **Controls-as-Code (CaC)** model.

a) **Scenario:** *CyberCorp*, a rapidly scaling FinTech startup, is experiencing compliance bottlenecks due to manual security reviews in its CI/CD pipeline. Their current process involves human auditors manually checking infrastructure configurations before deployment, leading to significant delays and increased risk of human error.

Task: As a GRC Engineer, you are tasked with advocating for the adoption of **Controls-as-Code (CaC)**. Beyond a mere definition, critically analyze how CaC fundamentally transforms *CyberCorp*'s compliance posture and operational efficiency within their CI/CD pipeline. Justify your arguments with specific examples of how CaC addresses the challenges of manual reviews. (5 Marks)

b) **Task:** Propose a **detailed, high-level architecture** for an automated, real-time compliance monitoring system for *CyberCorp*. This system must continuously check for critical misconfigurations such as "S3 Bucket Public Access" and "Unencrypted Databases" across their multi-cloud (AWS and Azure) environment. Your architecture should not only outline the components but also **justify the selection of each component** based on scalability, security, and integration with existing CI/CD processes. Include a

discussion on how this system would provide actionable alerts and integrate with a centralized GRC dashboard. (10 Marks)

(Marking: 4 Marks for Diagram/Workflow, 3 Marks for Component Selection, 3 Marks for Logic/Rule definition)

Question 2: GRC Integration (15 Marks) The "Engineering" in GRC Engineering implies building systems that are compliant by design.

a) **Scenario:** *GlobalBank*, a highly regulated financial institution, is adopting a hybrid cloud strategy. They need to ensure that all new infrastructure deployments (e.g., virtual machines, network configurations) in both their on-premise data centers and AWS cloud strictly adhere to internal security policies and external financial regulations.

Task: As a GRC Engineer, explain how **Policy-as-Code (PaC)**, utilizing tools like Open Policy Agent (OPA) or HashiCorp Sentinel, can be implemented to enforce governance at the infrastructure level for GlobalBank. Provide a concrete example of a policy (in pseudo-code or a high-level description) that would prevent the deployment of a virtual machine without mandatory encryption enabled. (7 Marks)

b) **Scenario:** *InnovateTech*, a rapidly expanding SaaS startup, has accumulated significant "Compliance Debt" due to its agile development cycles and focus on rapid feature delivery. They are now facing increased scrutiny from investors and potential clients regarding their GRC posture, which is largely manual and reactive.

Task: As a GRC consultant, you are tasked with advising InnovateTech on how **API-driven GRC platforms** can be leveraged to systematically reduce their compliance debt. Beyond defining compliance debt, explain with concrete examples how such platforms can integrate with InnovateTech's existing tools (e.g., Jira, GitHub, AWS) to automate evidence collection, streamline audit processes, and proactively identify compliance gaps. (8 Marks)

(Marking: 4 Marks for defining Compliance Debt, 4 Marks for API-driven solutions)

SECTION B: APPLIED RISK GOVERNANCE (30 MARKS)

Question 3: Scenario-Based Risk Assessment (30 Marks)

Scenario: **EcoStream**, a renewable energy data provider, is migrating its entire customer database (containing sensitive PII and energy consumption patterns) to a multi-cloud environment (AWS and Azure). They aim to comply with both **GDPR** (for European clients) and the **Nigerian Data Protection Act (NDPA)**.

- a) **Task:** For the "Data Breach during Migration" risk at EcoStream, perform a **Quantitative Risk Assessment** to estimate the Annualized Loss Expectancy (ALE), given a Single Loss Expectancy

(SLE) of \$500,000 and an Annualized Rate of Occurrence (ARO) of 0.1. Beyond the calculation, **critically interpret the significance of this ALE value for EcoStream's GRC strategy and budget allocation.** Discuss how this quantitative metric would influence a CISO's decision-making process regarding security investments. (10 Marks)

b) **Task:** Develop a comprehensive **Risk Treatment Plan** for EcoStream, addressing the "Data Breach during Migration" risk. For each of the four risk treatment options (Mitigate, Transfer, Avoid, Accept), propose a **specific, actionable engineering control or strategy** relevant to the EcoStream scenario. Crucially, for each chosen option, **justify your selection by** discussing its potential benefits, challenges, and the trade-offs involved in its implementation within a multi-cloud environment. (10 Marks)

c) **Task:** Identify and map three (3) specific controls from the **ISO 27001:2022** Annex A that are directly relevant to ensuring "Data Security and Confidentiality" for EcoStream, particularly concerning sensitive PII under the **Nigeria Data Protection Act (NDPA)**. For each chosen control, **justify its relevance** to the NDPA and describe, from an engineering perspective, **how EcoStream would implement and monitor this control** within its multi-cloud (AWS and Azure) environment. (10 Marks)

(Marking: 3 Marks for ISO Identification, 3 Marks for NDPA Mapping, 4 Marks for Technical Implementation explanation)

SECTION C: CASE STUDY – THE CORPORATE AFFAIRS COMMISSION (CAC) BREACH (40 MARKS)

Case Background: In 2026, the **Corporate Affairs Commission (CAC)** of Nigeria confirmed a significant cybersecurity incident involving unauthorized access to parts of its registration portal. This portal is the primary gateway for business registrations and corporate filings in Nigeria. In response, the commission temporarily shut down the portal to prevent further data exfiltration and began a forensic investigation. The incident raised concerns regarding the security of corporate data and the effectiveness of the commission's GRC framework.

Question 4: Governance & Risk Analysis (15 Marks)

- a) **Task:** Drawing upon the CAC Breach case, critically analyze the underlying **Governance failures** that likely contributed to the unauthorized access. Beyond simply stating the lack of "Continuous Monitoring" and "Identity Governance," elaborate on *how* these specific governance weaknesses create vulnerabilities in a digital registration portal. Propose **two concrete, proactive governance mechanisms that**, if implemented, could have significantly reduced the likelihood or impact of this breach. (7 Marks)

b) Task: The Corporate Affairs Commission (CAC) made the critical decision to restrict access to its registration portal following the breach. Evaluate this decision from two distinct GRC perspectives: Business Continuity Management (BCM) and Risk Appetite. Discuss the immediate and long-term implications of this action for the CAC and its stakeholders. Furthermore, propose and justify one alternative or supplementary action the CAC could have taken to manage the incident while minimizing disruption, considering both BCM and Risk Appetite principles. (8 Marks)

Question 5: Compliance & Regulatory Response (10 Marks) Under the **Nigeria Data Protection Regulation (NDPR)**, a data controller is required to notify the regulator (NDPC) of a breach within a specific timeframe.

a) Task: As a GRC expert advising the CAC, you are tasked with drafting a professional **Breach Notification Outline** to be submitted to the National Data Protection Commission (NDPC) under the **Nigeria Data Protection Regulation (NDPR)**. Beyond listing the required elements, **justify the inclusion and specific phrasing** of each key section (e.g., nature of the breach, categories of data compromised, estimated impact on data subjects, proposed remediation measures, and contact points). Emphasize how this notification can help manage reputational damage and demonstrate due diligence. (10 Marks)

(Marking: 2 Marks for Header/Format, 6 Marks for Content Accuracy, 2 Marks for Professional Tone)

Question 6: Engineering Remediation (15 Marks)

As a newly appointed **Lead GRC Engineer** at the CAC, your first task is to ensure this never happens again.

a) Task: As the newly appointed Lead GRC Engineer at the CAC, you are tasked with designing a **Zero Trust Architecture (ZTA)** for the registration portal to prevent future breaches. Propose a detailed ZTA implementation plan, focusing on the principles of "Never Trust, Always Verify." Specifically, elaborate on how "Least Privilege Access" and "Multi-Factor Authentication (MFA)" would be engineered and enforced across the portal's user base (internal administrators, external users). Discuss the **key challenges in** implementing ZTA in a legacy government system and how you would address them. (7 Marks)

b) Task: To enforce strict access governance post-breach, develop a **Controls-as-Code snippet** (using pseudo-code, Rego, or Terraform HCL) that implements a critical security control: **automatically preventing any administrative user from accessing the production database unless an active, approved Change Request (CR) ticket from an ITSM system (e.g., Jira Service Management) is explicitly linked and validated.**

Your snippet should include logic for:

- Identifying the administrative user attempting access.
- Checking for the presence and validity of a CR ticket.
- Denying access if the CR ticket is missing, invalid, or expired.

- Logging the access attempt and denial.

Justify your design choices and explain how this CaC implementation enhances the CAC's overall GRC posture. (8 Marks)

(Marking: 3 Marks for Syntax/Logic, 5 Marks for GRC Logic Integration)

END OF QUESTION PAPER